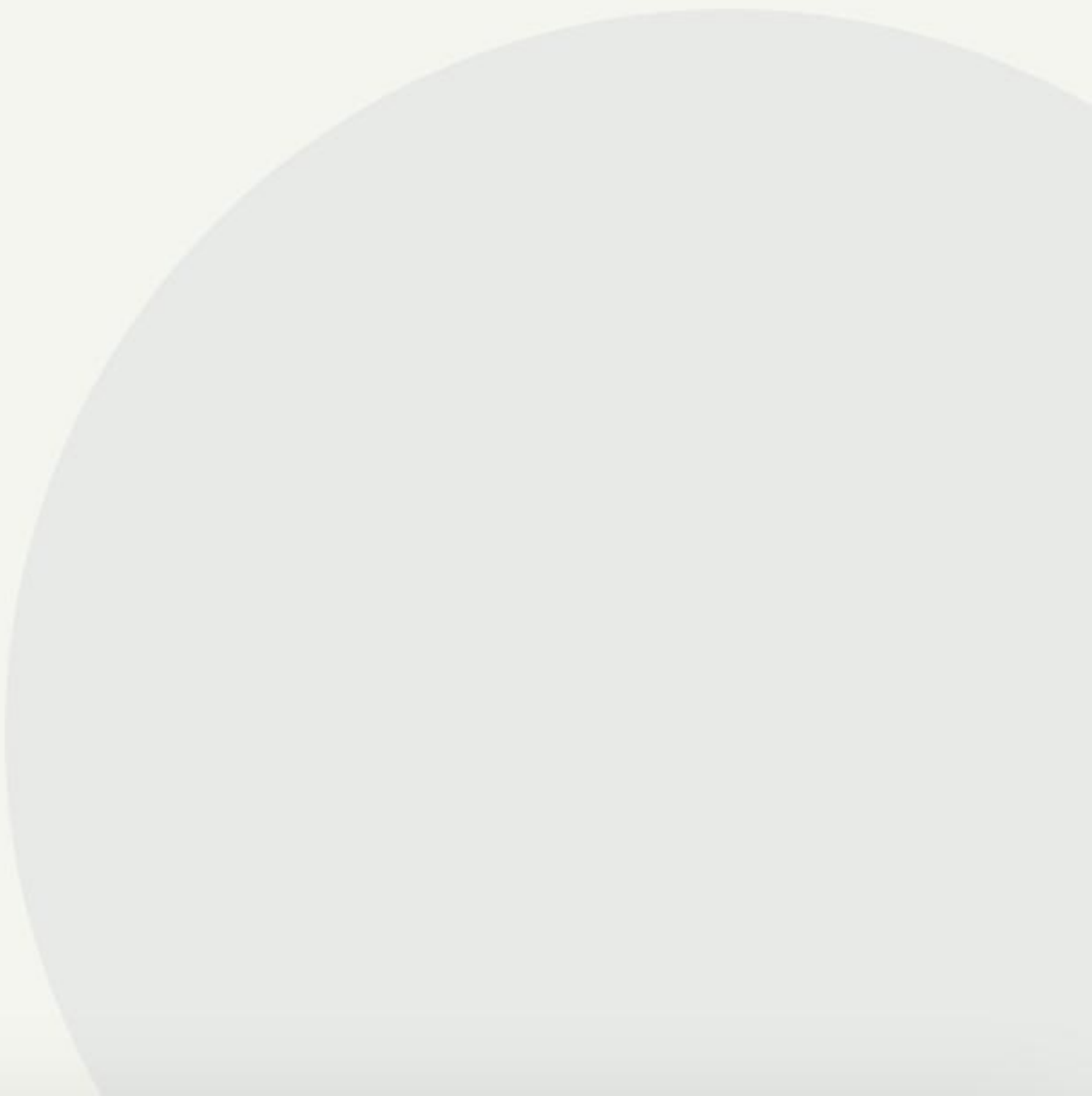

SECURE SIS

Online Secure Student Information System

Secure Software Engineering Course Project

PMU College of Computer Engineering | Spring 2025-2026



EXECUTIVE SUMMARY

The **Secure Student Information System (Secure SIS)** is a critical web platform designed to manage academic integrity.

- ✓ Protect academic identity and grade data.
- ✓ Enforce security across the full SDLC.
- ✓ Prevent SQLi, XSS, and unauthorized access.



PROJECT SCOPE

IN SCOPE

- Account Creation & Management
- Secure Login Authentication
- Role-Based Grade Posting
- Threat Modeling & Risk Assessment
- Secure Database Design

OUT OF SCOPE

- Mobile App Development
- Payment Processing Integration
- Biometric Authentication
- Production Cloud Scaling
- Enterprise ERP Integration

SECURITY REQUIREMENTS

- 🛡 **SR-1:** Use strong salted adaptive hashes (bcrypt/scrypt) for passwords.
- 🛡 **SR-2:** Mandatory use of Parameterized SQL queries for all DB access.
- 🛡 **SR-5:** Server-side validation and normalization for all user inputs.
- 🛡 **SR-7:** Enforce CSRF protection for all state-changing requests.
- 🛡 **SR-9:** Apply account lockout after repeated failed attempts.

CRITICAL ASSETS PROTECTED



GRADE RECORDS

Confidential academic data and history.



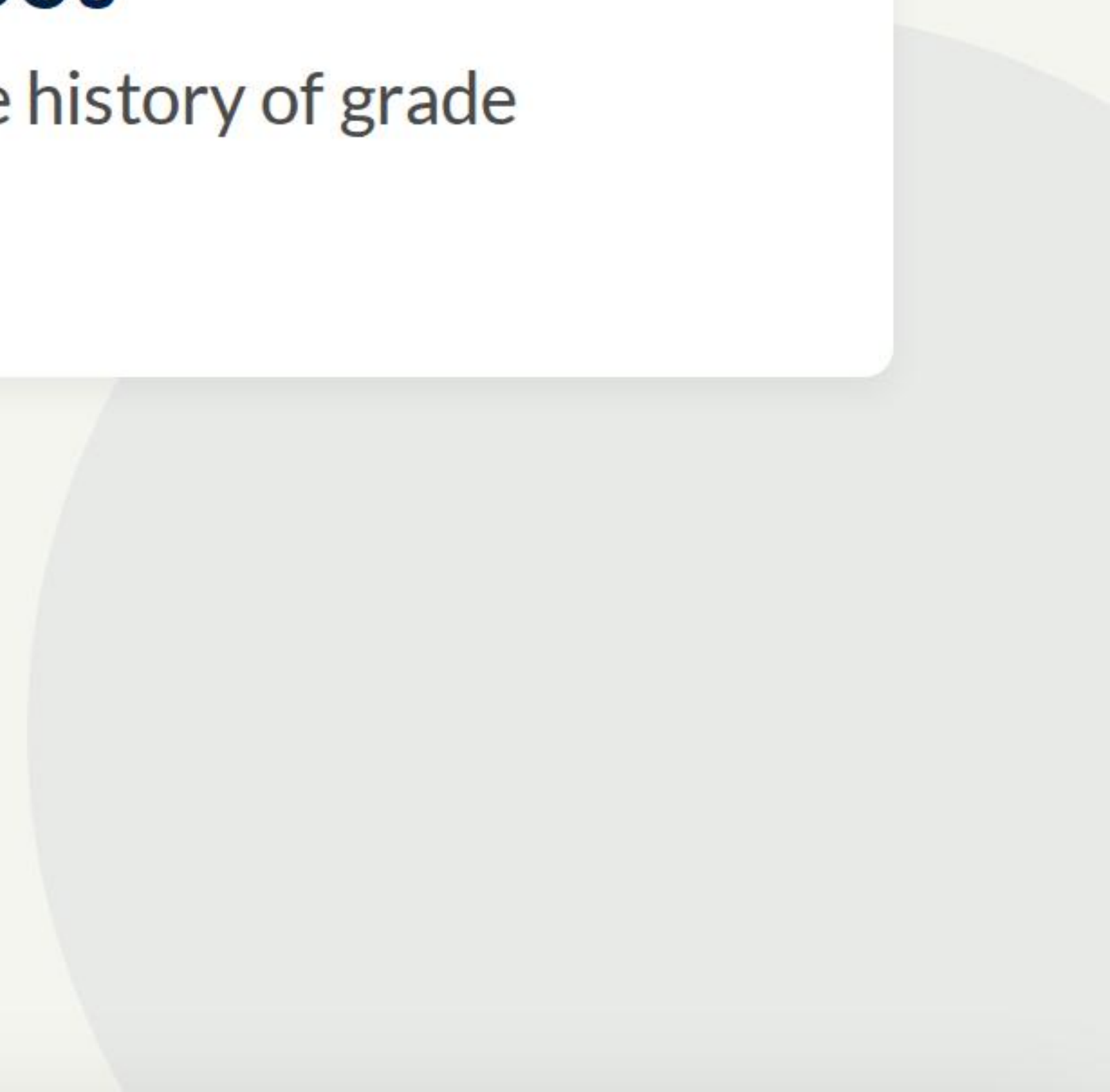
CREDENTIALS

User passwords and session identifiers.



AUDIT LOGS

Immutable history of grade changes.

A large, light gray circle is positioned in the bottom right corner of the slide, partially overlapping the right edge.

STRIDE THREAT MODELING

Category	Target Asset	Primary Mitigation
Spoofing	User Identity	Strong auth, secure sessions, rate limiting
Tampering	Grade Records	Authorization checks, audit logging
Repudiation	Actions	Timestamped, tamper-resistant logs
Information Disclosure	Sensitive Data	Encryption in transit, RBAC
Elevation of Privilege	Admin Rights	Route guards, server-side role checks

RISK ASSESSMENT MATRIX



Prioritizing High-Risk mitigations in the Implementation Phase.

SECURE ARCHITECTURE

A layered approach separating trust boundaries:

- **Presentation:** Secure Forms & CSRF Tokens.
- **Application:** RBAC, Business Logic & Validation.
- **Database:** Prepared Queries & Encryption.
- **Logging:** Security Event Redaction.



CORE DESIGN PRINCIPLES

100%

MEDIATION

Least Privilege: Users only access what is necessary.

Defense in Depth: Layered security controls.

Secure Defaults: Minimum role for new accounts.

Fail Securely: Generic errors to prevent leakage.

DEFENSIVE IMPLEMENTATION

social post scheduling, and in-app option to upgrade a social media post to a paid Facebook and Instagram ad

- Empowered other devs on the team through leadership by mentoring junior engineers, leading process experiments, running agile development meetings, and setting standards for use of AI-assisted coding tools

Senior Software Engineer, Redacted Interactive – Redacted, CA

Oct 2016 – Jan 2020

- Built and deployed a React Native replacement of the native Redacted Big Game on iOS and Android without down time for 1,000,000 DAU, gaining 50% fewer crashes, 66% faster initial load, and 33% better user ratings
- Developed security and gameplay features such as payable encryption, jackpots, bonus rounds and free spins for top performing slot machines in the Redacted Meh Game for iOS and Android using C# and Unity
- Migrated slots from Unity targeting PC to make them available in Redacted New Game for iOS and Android

Full-Stack Developer, Redacted Dating Startup – Redacted, CA

2015 – 2016

- Developed selection and prioritization service, user profile pages, matchmaking UI and other MVP features for the seed-stage startup's flagship dating app on iOS using Objective-C, Python and Postgres

iOS Engineer, Redacted Crypto Startup – Redacted, CA

2014 – 2015

- Developed QR code wallet sweep, multiple wallets, login screen, and other features for the seed-stage startup's flagship cryptocurrency wallet iOS app and back end using Objective-C, C, Python and Django

Full-Stack Engineer, Redacted Now Acquired Startup – Redacted, CA

2011 – 2014

- Developed UI and social features for 9 native and cross-platform mobile game apps for iOS and Android using Objective-C, Java, C++, PHP and MySQL resulting in top-grossing apps, unicorn startup status and acquisition

iOS Developer, Phone Book Software Company – Redacted, CA

2010 – 2011

Junior Software Engineer, Small AAA Gaming Studio – Redacted, CA

2007 – 2009

INPUT VALIDATION
Allowlist pattern matching for emails and passwords.



SQL INJECTION DEFENSE
Prepared statements using SQLite binding.



BRUTE FORCE CONTROL
Throttling and lockout after 5 failed attempts.

SECURITY TESTING PLAN

Test Category	Test Case	Expected Result
Injection	Submit admin' OR '1'='1	Login fails; no data leak
Access Control	Change ID in URL query	403 Forbidden Access
Brute Force	6 rapid failed login attempts	Account Locked out
Data Leakage	Force server 500 error	Generic message; no trace

Q&A

Thank you for your attention.

Secure SIS | Project Repository
[GitHub.com/SecureSIS-Project](https://github.com/SecureSIS-Project)

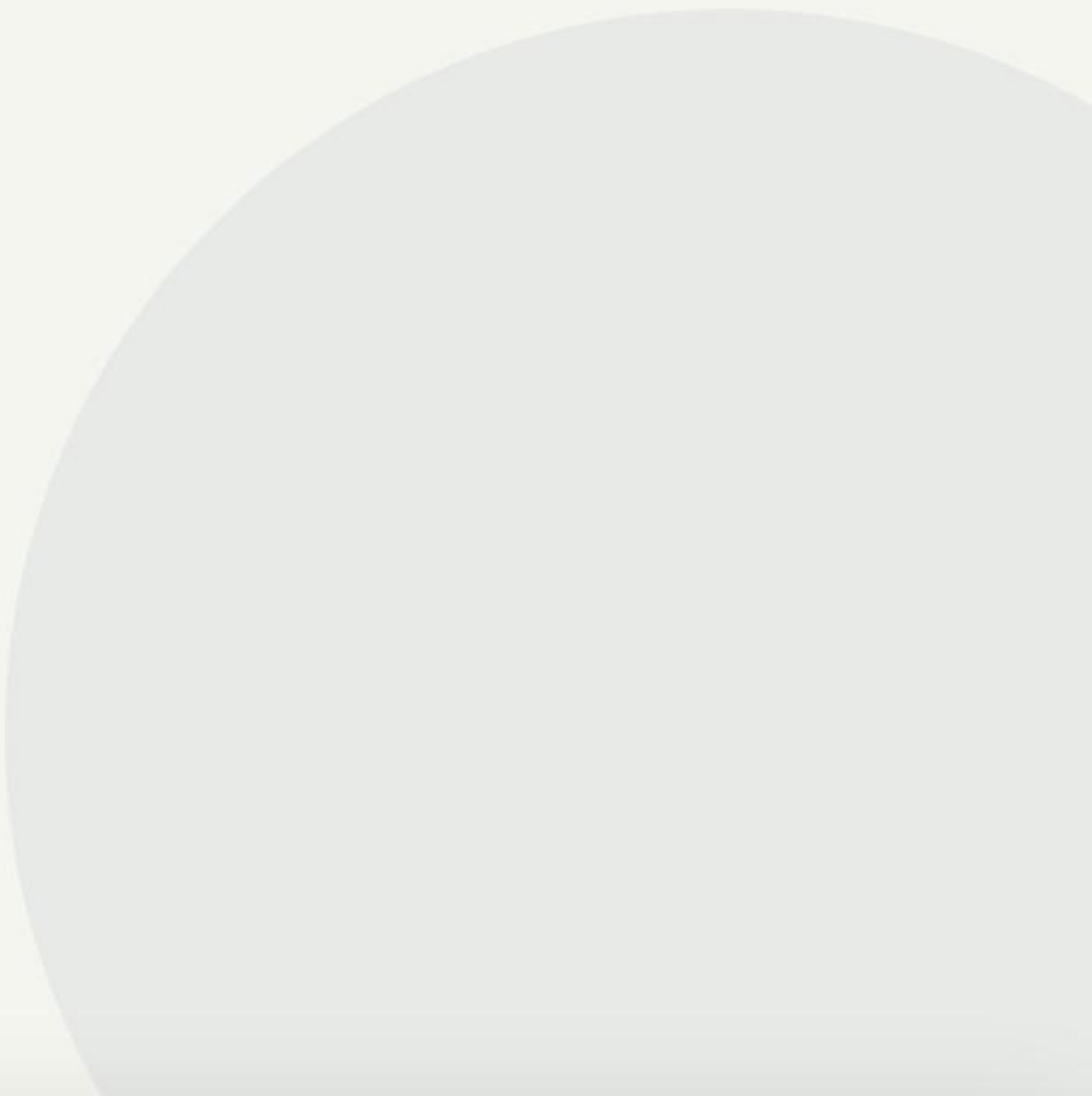


IMAGE SOURCES



<https://ukconstructionphotography.co.uk/wp-content/uploads/2025/07/the-catalyst-newcastle-architectural-photography-james-thompson-award-winning-1024x682.jpg>

Source: ukconstructionphotography.co.uk



<https://www.css-inc.com/wp-content/uploads/2022/08/iStock-1313044335-1024x576.jpg>

Source: www.css-inc.com



<https://preview.redd.it/senior-software-engineer-resume-second-post-v0-6yorxw4zpy4c1.png?width=5100&format=png&auto=webp&s=0dbd2e43c6d82c6ba7eccc28d404c55f406912b5>

Source: www.reddit.com



https://png.pngtree.com/png-vector/20250923/ourmid/pngtree-golden-ssl-security-badge-with-lock-and-laurel-wreath-icon-for-png-image_17551976.webp

Source: [pngtree.com](https://png.pngtree.com)



https://www.slideteam.net/media/catalog/product/cache/1280x720/c/y/cybersecurity_risk_management_framework_information_security_risk_management_dashboard_slide01.jpg

Source: www.slideteam.net